

Personal Project

Privacy Impact Assessment (PIA) Report

MediLink Online Clinic - GDPR Compliance Audit

Isuru Udana Pinthu.
[LinkedIn](#)

Disclaimer: *This Privacy Impact Assessment (PIA) report is a simulated exercise created solely for portfolio demonstration and educational purposes within the cybersecurity and GRC domain. "MediLink Online Clinic" is a fictional entity. Any resemblance to actual companies, platforms, or real-world data processing activities is entirely coincidental. This document does not represent a real compliance audit, nor does it constitute legal or regulatory advice.*

Contents

Executive Summary	3
System Architecture & Data Flow	3
Data Lifecycle & Processing Scope	4
GDPR Gap Analysis & Risk Findings	4
Strategic Recommendations & Remediation Plan	5
Engineering & Product Teams	5
Legal, Risk & Compliance Teams	5
Security Operations	6
Conclusion	6
References	6

Executive Summary

MediLink Online Clinic is a telehealth platform providing virtual medical consultations to residents of the European Union (EU). Because the platform systematically processes highly sensitive health records (Protected Health Information - PHI) and Personally Identifiable Information (PII), it is strictly subject to the General Data Protection Regulation (GDPR).

This Privacy Impact Assessment (PIA) was conducted to evaluate the platform's current data processing architecture, identify compliance gaps against standard GDPR requirements, and formulate pragmatic, risk-based remediation strategies. The objective is to balance regulatory compliance with business agility while safeguarding patient privacy.

System Architecture & Data Flow

A comprehensive understanding of the technical infrastructure is essential for evaluating privacy risks. MediLink operates within a cloud-native environment, interacting with several external sub-processors.

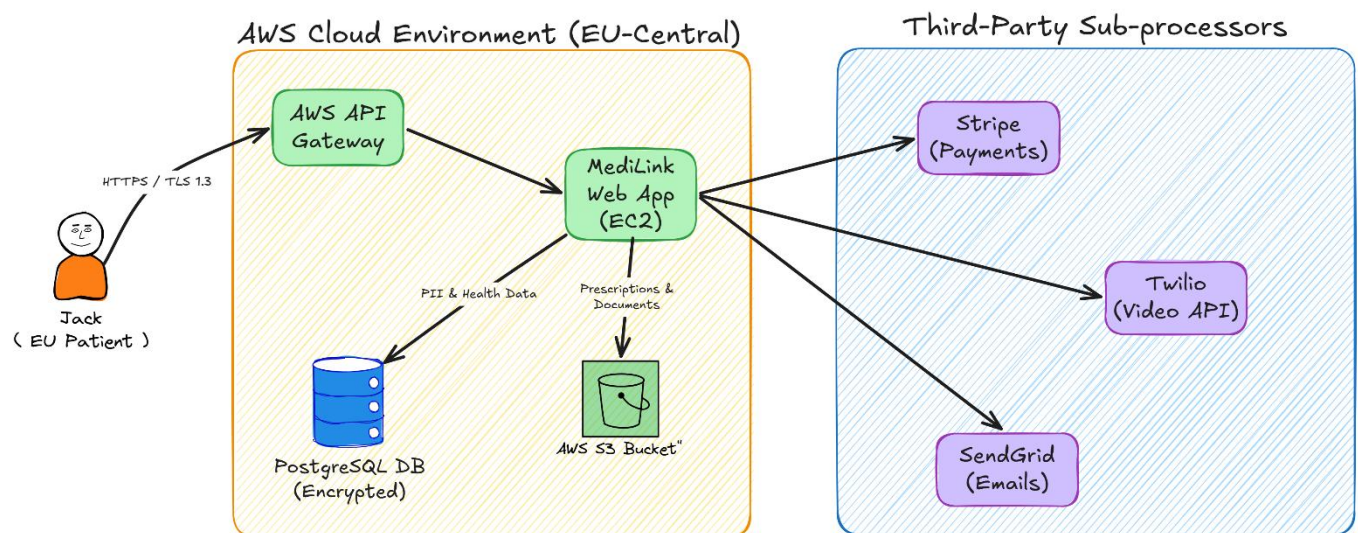


Figure 1- MediLink Cloud Architecture and Data Flow

As illustrated in the architecture diagram above, the data lifecycle flows as follows:

- **Ingestion:** EU Patients securely transmit data over HTTPS/TLS 1.3 to the AWS API Gateway, which routes requests to the MediLink Web App hosted on EC2 instances within the AWS EU-Central region.

- **Internal Storage:** Structured PII and health data are stored in an encrypted PostgreSQL Database. Unstructured data, such as prescriptions and medical documents, are routed to an AWS S3 Bucket utilizing Server-Side Encryption (SSE-KMS).
- **Third-Party Sub-processors:** The Web App integrates via APIs with external vendors for core functionalities: Stripe for payment processing, Twilio for secure video consultations, and SendGrid for email communications.

Data Lifecycle & Processing Scope

The assessment evaluated data across its entire lifecycle:

- **Data Collection:** Account data (Full name, DOB, contact details), Medical Data (History, doctor notes), Technical Data (IP, session logs), and Payment Data.
- **Retention Policies:** Medical records are retained for 7 years due to healthcare regulatory requirements. Account data is retained for 2 years post-inactivity. Logs are retained for 12 months.
- **Deletion Workflows:** Currently, deletion requests under GDPR Article 17 (Right to be Forgotten) are processed manually by database administrators.

GDPR Gap Analysis & Risk Findings

The following table outlines the technical and administrative vulnerabilities identified during the audit, mapped directly to GDPR requirements.

Risk ID	GDPR Requirement	Identified Vulnerability	Current Control	Risk Level
K-001	Storage Limitation	No automated deletion	Manual DB deletion process	High
K-002	Right to be Forgotten	Medical data exceptions unclear	Basic data retention policy	High
K-003	DPIA (Article 35)	Missing mandatory DPIA	Standard security review	High
K-004	Third-Party Contracts	Missing DPAs with all vendors	Basic vendor SLAs	High

K-005	Consent Management	No granular consent	Single 'Accept All' checkbox	Medium
K-006	Data Minimization	Collects unnecessary optional fields	Standard web form	Medium
K-007	Breach Notification	No formal testing	Basic incident response plan	Medium
K-008	Right to Access	Slow response times	Email-based manual ticketing	Medium
K-009	Security of Processing	No automated AWS backup testing	AWS automated daily backups	Medium
K-010	Security of Processing	No active alerting for DB access	Basic AWS CloudWatch logging	High

[Full Graph link](#)

Strategic Recommendations & Remediation Plan

To address the identified gaps and mature MediLink's privacy posture, the following cross-functional initiatives are recommended:

Engineering & Product Teams

- **Automated Data Lifecycle:** Develop and deploy automated scripts for the deletion of non-medical PII upon the expiration of retention periods to eliminate manual database queries.
- **Consent Granularity:** Redesign the user registration portal to replace the 'Accept All' checkbox with granular consent toggles (e.g., separating marketing from core services).
- **Security Monitoring:** Configure proactive AWS CloudWatch alerts specifically for unauthorized or anomalous access attempts to the PostgreSQL database.
- **Resilience Testing:** Implement quarterly backup restoration tests to validate data availability in compliance with Article 32.

Legal, Risk & Compliance Teams

- **Vendor Risk Management:** Draft, negotiate, and execute formal Data Processing Agreements (DPAs) with Stripe, Twilio, and SendGrid to ensure downstream compliance.

- **Policy Documentation:** Revise the public-facing Privacy Notice and internal data retention policies to explicitly outline healthcare regulatory exceptions to the "Right to be Forgotten."
- **Impact Assessments:** Initiate a formal Data Protection Impact Assessment (DPIA) covering the core telehealth processing activities.

Security Operations

Incident Readiness: Plan and execute breach response tabletop exercises to validate the organization's ability to notify supervisory authorities within the 72-hour mandate (Article 33).

Conclusion

While MediLink utilizes secure infrastructure components (AWS S3 SSE-KMS, encrypted databases), the reliance on manual privacy workflows and the absence of formalized third-party agreements present significant regulatory risks. By executing the remediation strategies outlined above, MediLink can achieve a robust GDPR compliance posture while maintaining operational efficiency.

References

- **General Data Protection Regulation (GDPR) Official Text:** <https://gdpr-info.eu/>
- **UK ICO Guidance on Privacy Impact Assessments (PIAs):** <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/>
- **AWS Security & Compliance Data Privacy:** <https://aws.amazon.com/compliance/data-privacy-faq/>